

MCP Borrowed LSP's Design

But Skipped LSP's Lesson

Gorkem Ercan

CTO, Jozu

What this talk will cover

- How LSP ended up with fragmented packaging and trust
- Where MCP packaging stands today
- Which trust layers are still missing
- How OCI-based packaging closes the gap without changing MCP

MCP inherited LSP's shape

Handshake, Capability negotiation, JSON-RPC



What LSP never defined

It standardized the conversation: M editors $\times$ N languages became $M + N$.

- Packaging or verification
- A trust boundary: a local subprocess, running with your privileges
- Authentication or authorization: remote was someone else's problem
- A distribution channel: Marketplace, Open VSX, mason, npm, distros, none won

The matrix returns

LSP's promise: write the server once, every editor can use it.

- The protocol delivered that. One implementation, many clients.
- Distribution did not. The same server is packaged again per ecosystem.
- VS Code extension, mason recipe, npm package, distro package, brew formula
- Signing arrived later, one channel at a time
- One binary, N packagings, N update paths, N trust decisions

MCP repeats it, with a bigger threat model

Same shape as LSP. Not the same stakes.

- LSP server: arbitrary code, but scoped to reading your source
- MCP server: arbitrary code holding credentials, data, shells, and browsers
- Agents load servers dynamically and compose many of them at once
- Inputs are untrusted: tool descriptions and tool output steer the agent
- A bad package is not just buggy, it is an execution path

Today's packaging options fall short

- Official registry: metadata and discovery, trust delegated to npm and PyPI
- MCPB/DXT: familiar bundle shape, but repeats the extension packaging model
- Vendor provenance exists, but is trapped inside vendor-specific workflows

Demo: We already know how to solve this

Package with KitOps. Verify with cosign. The two share no tooling.

1. Bundle the server as an MCPB
2. Package the bundle as an OCI artifact
3. Sign it, and attest what source and build produced it
4. Verify before the agent loads it

What OCI buys you immediately

- Registry neutrality
- Existing signing and attestation tooling
- Policy engines that already work in production
- Familiar operational patterns for promotion and verification

Takeaways

- Packaging is part of the security model
- Vendor-specific signing does not create open trust
- Provenance must be portable and verifiable before execution
- MCP can reuse existing cloud-native supply chain tooling instead of rebuilding it

Thank you

Gorkem Ercan
gorkem@jozu.com

jozu.com · kitops.org